AI Security

Quick Audit Toolkit

PREMIUM EDITION

A practical framework to identify AI risks, data exposure issues, and compliance challenges across your organization.

Organization:	_____
Prepared By:	_____
Date:	_____
Audit Scope:	_____

■■ **CONFIDENTIAL** — This document contains sensitive security information. Distribute only to authorised personnel.

Table of Contents

1.	Introduction & Purpose	3
2.	Five-Step AI Security Audit Framework	3
3.	AI Usage Inventory Worksheet	4
4.	Data Exposure Risk Assessment	5
5.	Vendor Security Evaluation Form	6
6.	AI Incident Response Template	7
7.	Executive AI Risk Report Template	8
8.	Risk Level Reference Guide	9

1. Introduction & Purpose

Artificial intelligence tools are rapidly becoming embedded in modern business operations. From customer-facing chatbots to internal data analytics engines, AI adoption is accelerating across industries. However, this growth introduces new categories of risk that traditional security frameworks do not fully address.

This toolkit helps organizations **identify AI risks**, assess **data exposure issues**, evaluate **vendor security posture**, and address **compliance challenges**. It is designed to be actionable, repeatable, and scalable for organizations of all sizes.

2. Five-Step AI Security Audit Framework

01
Identify AI Tools
Catalog all AI tools used across departments

→

02
Evaluate Data Exposure
Assess what sensitive data enters AI systems

→

03
Assess Vendor Security
Review third-party AI providers' posture

→

04
Map Compliance Impact
Identify regulatory requirements & gaps

→

05
Implement Governance
Define controls, policies & ownership

■ **Best Practice:** Repeat this audit cycle quarterly or whenever a new AI tool is introduced to your environment. Assign a named owner for each step.

3. AI Usage Inventory Worksheet

Document every AI tool deployed or used across your organization. Include shadow-IT tools (tools used without formal IT approval).

AI Tool / Platform	Department	Business Use	Data Entered	Risk Level	Notes / Owner

LOW	Minimal risk; monitor periodically
MEDIUM	Review within 30 days
HIGH	Immediate remediation required
CRITICAL	Escalate to CISO immediately

■ **Tip:** Use the Risk Level key above when completing the Risk Level column. Prioritise HIGH and CRITICAL items for immediate follow-up.

4. Data Exposure Risk Assessment

Evaluate whether sensitive data is being submitted into AI tools in ways that could create privacy, security, or compliance exposures. Answer each question for your organization.

#	Assessment Item	Yes	No	Notes
1	Employees enter personally identifiable information (PII) into AI tools	■	■	
2	Employees enter confidential business data (e.g., strategy, M&A;) into AI tools	■	■	
3	AI tools process financial data (accounts, transactions, forecasts)	■	■	
4	AI tools process healthcare or medical data (PHI / HIPAA scope)	■	■	
5	AI tools process legal documents, contracts, or privileged communications	■	■	
6	AI tools process HR or employee performance data	■	■	
7	AI tools have access to internal file systems or databases	■	■	
8	AI-generated outputs are shared externally without review	■	■	
9	AI vendor data retention / deletion policies are unknown or unreviewed	■	■	
10	Employees have received training on safe AI data practices	■	■	
11	A formal AI acceptable use policy (AUP) is in place	■	■	
12	AI tool access is logged and monitored	■	■	

■■ Any **'Yes'** response to items 1–9 or **'No'** response to items 10–12 should be flagged as a risk item and included in the Executive AI Risk Report (Section 7).

5. Vendor Security Evaluation Form

For each AI vendor or platform in use, complete the fields below. Request vendor security documentation (SOC 2, ISO 27001, GDPR DPA) as evidence.

Vendor / Platform	Data Retention Policy	Encryption Standards	Compliance Certs	Risk Level	Action Required

Key Questions to Ask Every AI Vendor:

Data Storage	Where is our data stored? What regions? Which cloud provider?
Data Retention	How long is our data retained? Can we request deletion?
Training Usage	Is our data used to train or fine-tune AI models?
Encryption	Is data encrypted in transit (TLS 1.2+) and at rest (AES-256)?
Compliance	Do you hold SOC 2 Type II, ISO 27001, or GDPR certifications?
Breach Notification	What is your incident response and breach notification SLA?
Sub-processors	Which sub-processors handle our data? Are they contractually bound?

6. AI Incident Response Template

Use this template to document and manage any AI-related security incident, data breach, or governance violation.

Incident Reference #
Auto-generate or assign sequentially (e.g., INC-2025-001)

Incident Date & Time
Date and time the incident was detected or reported

Reported By
Name and role of the person who identified the incident

AI Tool Involved
Name of the AI platform or system involved

Data Potentially Exposed
Describe the type and volume of data that may be affected

Initial Severity
Low / Medium / High / Critical — based on impact assessment

Containment Actions Taken
Steps immediately taken to contain or limit exposure

Affected Parties Notified
List internal and external parties notified (date/method)

Root Cause (Preliminary)
Initial assessment of how the incident occurred

Remediation Plan
Specific actions, owners, and deadlines to resolve and prevent recurrence

■ **Regulatory Reminder:** Under GDPR Art. 33, personal data breaches must be reported to the supervisory authority within **72 hours** of becoming aware. Under HIPAA, breaches involving PHI have specific notification timelines.

7. Executive AI Risk Report Template

Synthesize audit findings into a concise executive summary for leadership, the board, or compliance stakeholders.

Executive Summary

Provide a 2–3 sentence overview of the audit scope, key findings, and overall risk posture.

AI Tools Identified

List all AI tools discovered. Note which are approved vs. shadow-IT.

Key Risks Identified

Enumerate the most significant risks (data exposure, vendor gaps, policy gaps, compliance failures).

Compliance Implications

Identify applicable regulations (GDPR, HIPAA, SOC 2, CCPA, etc.) and any identified gaps or violations.

Recommended Controls

Provide prioritised recommendations with suggested owners and target completion dates.

Next Audit Date

Proposed date for the next scheduled AI security audit.

8. Risk Level Reference Guide

Use the following criteria to consistently assign risk levels throughout the toolkit.

Risk Level	Criteria	Response Timeline	Escalation Required
■ LOW	No sensitive data involved; tool is well-established; vendor is certified	Review at next quarterly audit	No
■ MEDIUM	Some sensitive data exposure; vendor compliance partially verified; policy gaps exist	Remediate within 30 days	Manager
■ HIGH	Confirmed sensitive data in unmanaged AI tool; missing vendor contracts; regulatory gap	Immediate remediation	CISO / DPO
■ CRITICAL	Active breach or confirmed data exfiltration; regulatory violation probable	Activate Incident Response NOW	Board / Legal

Compliance Framework Quick Reference

Regulation	Scope	Key AI Considerations
GDPR	EU personal data	Data minimisation, DPA with vendors, 72-hr breach notification
HIPAA	US healthcare (PHI)	No PHI in unmanaged AI tools; BAA required from AI vendors
SOC 2	Service organisations	Availability, confidentiality & security of AI-processed data
CCPA	California consumer data	Right to deletion; AI profiling disclosure obligations
ISO 27001	Information security mgmt.	AI tools must fall within ISMS scope and risk treatment
NIST AI RMF	US AI risk management	Governance, mapping, measurement & management of AI risk

■ **Next Steps:** Complete each worksheet, compile findings into the Executive AI Risk Report, assign remediation owners, and schedule the next audit. Consider integrating this toolkit into your annual security review cycle and vendor onboarding process.

© Evolve Edge — AI Security Quick Audit Toolkit Premium Edition. For internal use only. Unauthorised distribution prohibited.